Mini-Internet GNS3, pare-feu OPNsense et DMZ

MAHDID Farès
Novembre 2026

Résumé

Le projet en bref. Dans un réseau d'entreprise simulé (un « mini-Internet » sous GNS3), j'ai remplacé le routeur Linux de l'entreprise fictive Clover Corp. par un pare-feu OPNsense. J'ai isolé les serveurs exposés dans une DMZ, limité leurs sorties au web, réservé l'administration du pare-feu à un réseau dédié (MGMT) et activé la journalisation des blocages.

Ce que j'ai démontré. À l'aide des journaux du pare-feu, j'ai prouvé qu'un serveur compromis ne peut ni atteindre les postes de travail ni ouvrir une connexion sortante sur un port quelconque, et que les postes ne peuvent pas accéder à l'interface d'administration.

Limite. La liaison avec l'Internet simulé ne fonctionnait pas : le NAT et les échanges avec l'extérieur n'ont donc pas été validés (voir partie 9).

Compétences mises en œuvre : configuration d'un pare-feu, segmentation réseau et DMZ, filtrage sortant, analyse de journaux, méthode de test et de preuve, diagnostic sous Linux et virtualisation (GNS3, QEMU/KVM).

Sommaire

1. Contexte et objectif
2. Pourquoi c'est important en cybersécurité
3. Architecture du projet
4. Décisions de sécurité (avant / après)
5. Mise en œuvre
6. Tests et preuves
7. Scénario d'incident
8. Limites
9. Bilan : compétences développées

1. Contexte et objectif

Ce projet reprend le « mini-Internet » réalisé l'an dernier sous GNS3. Un petit Internet simulé avec un backbone, deux opérateurs (Daisy Telecom et Lotus Telecom) et plusieurs réseaux clients. L'entreprise Clover Corp. y disposait d'un routeur Linux qui filtrait le trafic avec iptables.

Ce routeur avait des limites, le trafic sortant était presque entièrement autorisé, les blocages n'étaient pas journalisés et l'administration se faisait depuis la console du routeur. Autrement dit, si un serveur était compromis, rien ne l'empêchait de contacter l'extérieur, et rien ne laissait de trace.

Objectif, remplacer ce routeur par un pare-feu OPNsense, placer les serveurs exposés dans une DMZ, durcir la politique de filtrage, puis prouver chaque amélioration par des tests.

Tout le travail est réalisé dans un laboratoire isolé (GNS3 avec QEMU/KVM sous Arch Linux). Aucun test n'est effectué sur des systèmes extérieurs.

Pourquoi OPNsense

OPNsense est un pare-feu open source, administrable par une interface web, qui journalise le trafic de manière lisible. Chaque ligne indique l'interface, la source, la destination, l'action et la règle concernée. Il permet de nommer les règles, de les regrouper avec des alias et de sauvegarder la configuration. On retrouve ce type d'outil dans de nombreuses petites et moyennes structures, ce qui en fait un bon terrain d'apprentissage par rapport à des règles iptables écrites à la main.

Notions utilisées :

Pare-feu stateful : il mémorise les connexions ; les réponses à une connexion autorisée passent sans règle supplémentaire.

Refus par défaut : tout ce qui n'est pas explicitement autorisé est bloqué.

DMZ : zone des serveurs exposés à Internet, séparée du réseau interne. Si un serveur est compromis, cela limite la propagation vers les postes.

DNAT / SNAT : le DNAT redirige une connexion entrante vers un serveur interne ; le SNAT remplace l'adresse privée d'un paquet sortant par l'adresse publique.

Alias : un nom donné à une liste d'adresses, de réseaux ou de ports, pour écrire des règles lisibles (par exemple PORTS_WEB pour les ports 80 et 443).

2. Pourquoi c'est important en cybersécurité

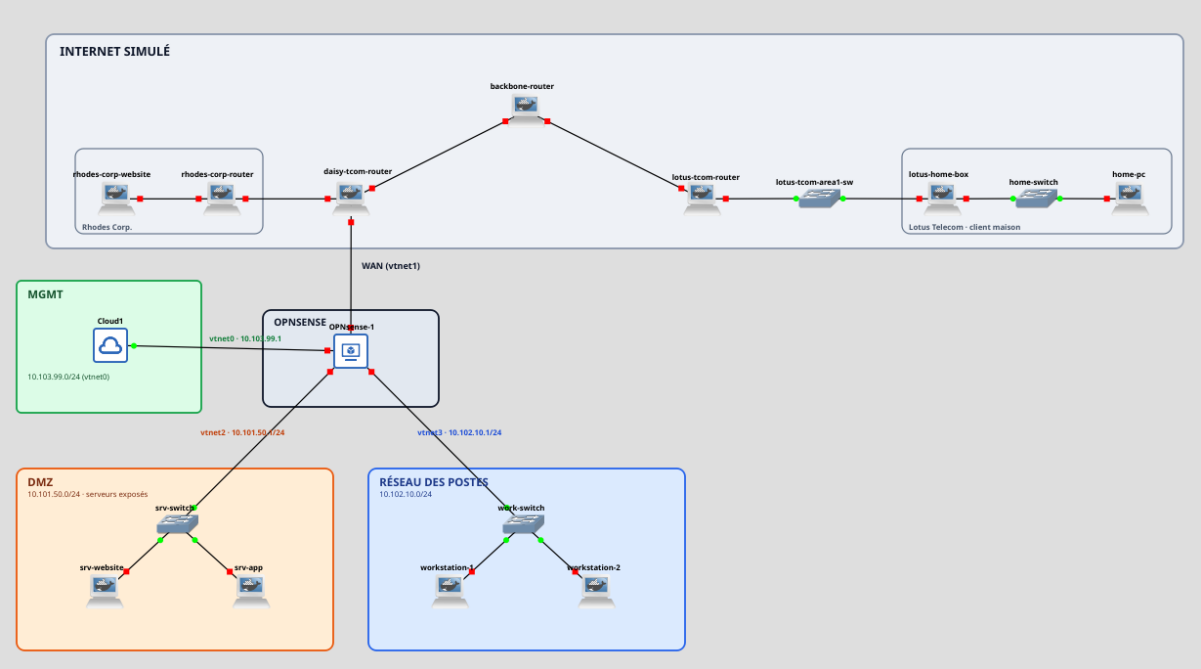
Un serveur exposé à Internet est la cible la plus probable d'une attaque. Une fois qu'un attaquant en a pris le contrôle, il cherche en général à faire trois choses : se déplacer vers le réseau interne, contacter son propre serveur pour recevoir des ordres (par exemple avec un shell inverse), et sortir des données. Le pare-feu est la barrière qui rend ces actions difficiles et visibles. Chaque choix du projet répond à l'un de ces risques.

Principe de sécurité	Application dans le projet	Menace limitée
Segmentation et défense en profondeur	Quatre zones séparées (WAN, DMZ, USERS, MGMT) avec une politique entre chaque zone	Déplacement latéral vers les postes
Moindre privilège	Seuls les flux nécessaires sont autorisés ; tout le reste est refusé par défaut	Ouverture de services ou de ports non prévus

Principe de sécurité	Application dans le projet	Menace limitée
Filtrage du trafic sortant	Les serveurs et les postes ne sortent que sur le web (TCP 80 et 443)	Shell inverse et canal de commande (« Command and Control »), exfiltration de données
Réduction de la surface d'attaque	Pas de réponse au ping depuis Internet, interface web d'administration limitée à MGMT	Reconnaissance du réseau (« Discovery »), prise de contrôle du pare-feu
Isolation de l'administration	Réseau MGMT dédié, inaccessible depuis les postes et les serveurs	Compromission du pare-feu lui-même
Journalisation et détection	Les règles de blocage écrivent dans les journaux, avec une description	Attaque silencieuse : sans trace, on ne peut ni détecter ni enquêter

Le point de vue Blue Team. Bloquer ne suffit pas : l'équipe de défense doit aussi savoir qu'une tentative a eu lieu. C'est pourquoi chaque règle de blocage importante est journalisée. Une ligne rouge dans le journal est un indice exploitable : elle indique quelle machine a essayé de joindre quoi, quand, et quelle règle l'a arrêtée.

3. Architecture du projet

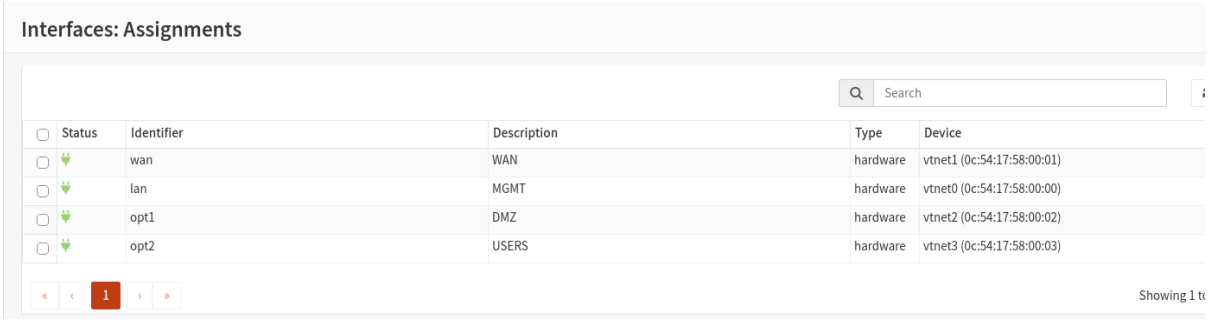


- ***topologie GNS3 du projet avec OPNsense***

OPNsense est une machine virtuelle QEMU avec quatre interfaces réseau, chacune reliée à une zone :

Zone	Interface	Réseau	Rôle
WAN	vtnet1	198.51.100.123/29 (passerelle .121)	Lien vers l'Internet simulé
DMZ	vtnet2	10.101.50.0/24	srv-website (.10) et srv-app (.20)
USERS	vtnet3	10.102.10.0/24	Postes de travail, DHCP .100 à .200
MGMT	vtnet0	10.103.99.0/24	Administration depuis mon PC (tap0)

Chaque zone a un rôle de sécurité différent. La DMZ héberge les serveurs que l'extérieur peut atteindre : ce sont les machines les plus exposées, donc celles dont on limite le plus les droits. Les postes (USERS) appartiennent au réseau interne : ils ne doivent pas être joignables depuis la DMZ. Le réseau MGMT n'existe que pour administrer le pare-feu, depuis mon PC, par une interface virtuelle (tap0) reliée à un nœud Cloud de GNS3 : OPNsense n'est pas connecté à mon réseau personnel.



- attribution des interfaces dans OPNsense (Interfaces > Assignments) : WAN, MGMT, DMZ et USERS

4. Décisions de sécurité (avant / après)

Le tableau suivant résume ce qui change entre l'ancien routeur (v1) et OPNsense (v2), et le risque que chaque changement réduit.

Sujet	v1 (iptables)	v2 (OPNsense)	Risque réduit
Sortie des serveurs	Tout autorisé	TCP 80/443 seulement	Shell inverse, exfiltration de données
Sortie des postes	Tout autorisé	TCP 80/443 et ICMP	Moindre privilège
Serveurs vers postes	Refusé	Refusé et journalisé	Rebond après une compromission
Ping depuis Internet	Réponse	Pas de réponse	Reconnaissance du réseau
Administration	Console du routeur	Interface web limitée à MGMT	Prise de contrôle du pare-feu
Refus final	Implicite	Règle explicite avec log	Traçabilité

Le raisonnement derrière chaque décision

Limiter la sortie des serveurs au web. Un serveur web n'a besoin d'accéder qu'aux ports 80 et 443 (mises à jour). Si un attaquant en prend le contrôle et essaie d'ouvrir un shell inverse sur un autre port (par exemple 4444), le pare-feu le bloque.

Refuser et journaliser DMZ vers postes. La v1 refusait déjà ce trafic, mais sans trace. Le journaliser transforme une simple interdiction en alerte exploitable : une tentative de rebond devient visible.

Ne plus répondre au ping depuis Internet. Un ping est souvent la première étape d'une reconnaissance, ne pas répondre donne moins d'informations à un attaquant qui scanne le réseau.

Isoler l'administration : Une personne qui contrôle le pare-feu contrôle tout le réseau, son interface web ne doit donc être accessible que depuis un réseau réservé.

Écrire une règle de refus final explicite : Le refus par défaut existe déjà, mais une règle visible, avec une description et un journal, permet de voir ce qui est refusé.

5. Mise en œuvre

5.1 Étapes principales

Installation d'OPNsense dans GNS3 (machine QEMU, 4 interfaces) et accès à l'interface web via une interface tap0.

Remplacement du routeur Clover Corp, câblage des quatre interfaces et attribution des mêmes adresses de passerelle qu'avant, pour que les hôtes (serveurs et postes) ne changent pas de configuration.

Configuration de la passerelle par défaut, des alias (HOST_WEBSITE, RFC1918, PORTS_WEB), du DNAT (TCP 80 vers srv-website) et du SNAT. Cette partie n'a pas pu être validée par un test depuis Internet (voir partie 9).

Service DHCP (Kea) pour les postes de travail.

Passage de la politique « équivalente à la v1 » à la politique améliorée.

5.2 Règles de pare-feu de la version améliorée

OPNsense lit les règles de haut en bas, sur le trafic qui entre par l'interface concernée, et applique la première qui correspond. L'ordre est donc essentiel : les blocages vers les zones sensibles sont placés avant l'autorisation de l'ICMP vers le pare-feu. Dans les règles, la notation « ! RFC1918 » signifie « tout sauf les réseaux privés », c'est-à-dire « vers l'extérieur ».

Interface DMZ

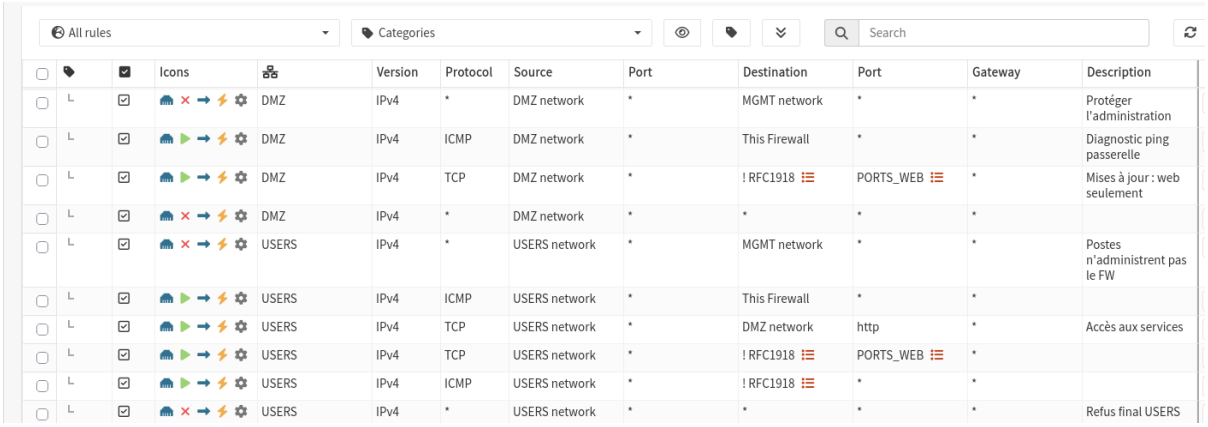
#	Action	Source → Destination	Port	Rôle
D1	Bloquer + log	DMZ → USERS	tous	Empêcher le rebond vers les postes
D2	Bloquer + log	DMZ → MGMT	tous	Protéger l'administration
D3	Autoriser	DMZ → pare-feu (ICMP)	ICMP	Diagnostic
D4	Autoriser	DMZ → hors réseaux privés	80, 443	Mises à jour : web seulement
D9	Bloquer + log	DMZ → tout	tous	Refus final visible dans les logs

Interface USERS

#	Action	Source → Destination	Port	Rôle
U1	Bloquer + log	USERS → MGMT	tous	Les postes n'administrent pas le pare-feu
U2	Autoriser	USERS → pare-feu (ICMP)	ICMP	Diagnostic
U3	Autoriser	USERS → DMZ	80	Accès aux serveurs web
U4	Autoriser	USERS → hors réseaux privés	80, 443	Navigation web
U9	Bloquer + log	USERS → tout	tous	Refus final visible dans les logs

Interface WAN : seule règle d'entrée, TCP 80 vers srv-website (DNAT). Le ping vers le pare-feu n'est plus autorisé.

Interface MGMT : accès HTTPS (443) au pare-feu, et accès de dépannage (SSH, HTTP, HTTPS, ICMP) vers la DMZ et les postes. La règle automatique « anti-lockout » d'OPNsense garantit en plus que l'administrateur ne se coupe pas lui-même de l'interface web.



- ***règles de pare-feu des interfaces DMZ et USERS dans OPNsense (capture partielle)***

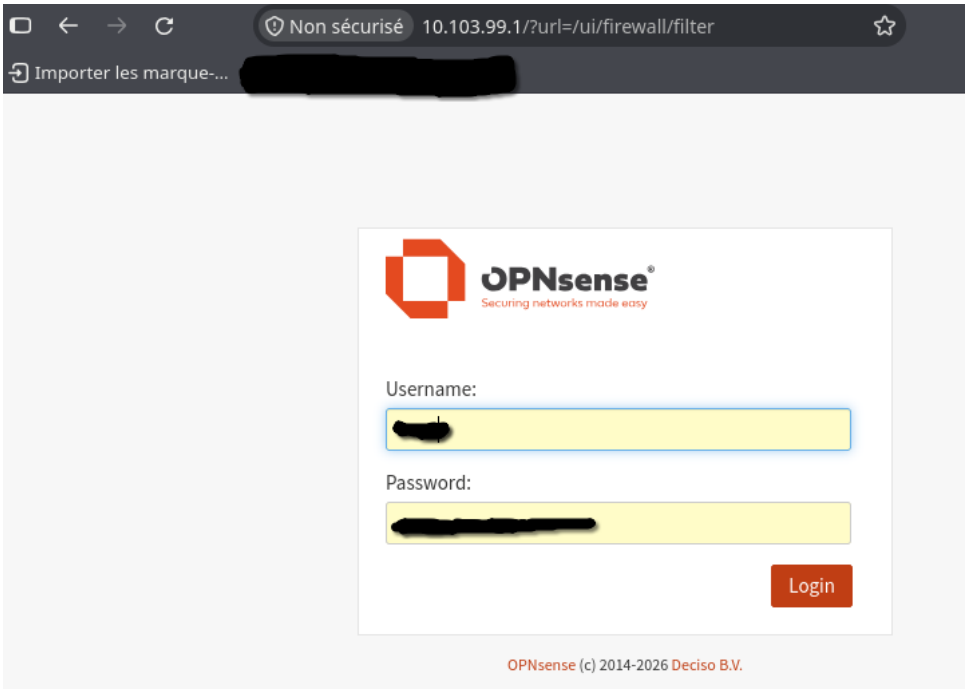


- -

- ***règles de l'interface MGMT : HTTPS vers le pare-feu, et dépannage vers la DMZ et les postes***

5.3 Accès à l'administration

L'interface web d'OPNsense est accessible depuis mon PC sur l'adresse 10.103.99.1, réseau MGMT. Les identifiants sont masqués sur la capture.



- ***page de connexion d'OPNsense depuis le réseau MGMT (identifiants masqués)***

6. Tests et preuves

6.1 Méthode

Chaque test indique ce qui est attendu et ce qui est observé. Trois règles de lecture :

Timeout ou refus. Un délai d'attente dépassé (timeout) signifie que le pare-feu a jeté le paquet. Un « connection refused » immédiat signifierait au contraire que le paquet est passé mais que le port est fermé.

Le journal comme preuve. Un ping sans réponse peut venir d'un câble débranché. Seule la ligne de blocage dans Firewall > Log Files > Live View prouve que c'est le pare-feu qui a décidé.

Un test négatif et un test positif. Un blocage n'a de valeur que si le trafic légitime passe. J'ai donc testé aussi ce qui doit être autorisé.

6.2 Tableau récapitulatif

Test	Depuis	Commande	Attendu	Obtenu
T01	poste (workstation-1)	curl http://10.101.50.10	Page web (autorisé)	Conforme : réponse de srv-website
T05	poste	curl -k https://10.103.99.1	Bloqué + log	Conforme : blocage U1 dans le journal
T06	poste	curl -k -m 3 https://10.102.10.1	Timeout	Conforme : timeout de 3 s
T07	srv-website	ping vers un poste	Bloqué + log	Conforme : 100 % de perte, blocage D1
T10	srv-website	curl -m 3 http://192.0.2.150:4444	Timeout (shell inverse bloqué)	Conforme : timeout, blocage dans la DMZ
T03, T04, T09, T11, T13	poste, srv-website, Internet	accès à Rhodes et depuis Internet	—	Non testés : liaison WAN indisponible

6.3 Test T07 : un serveur compromis ne peut pas atteindre les postes

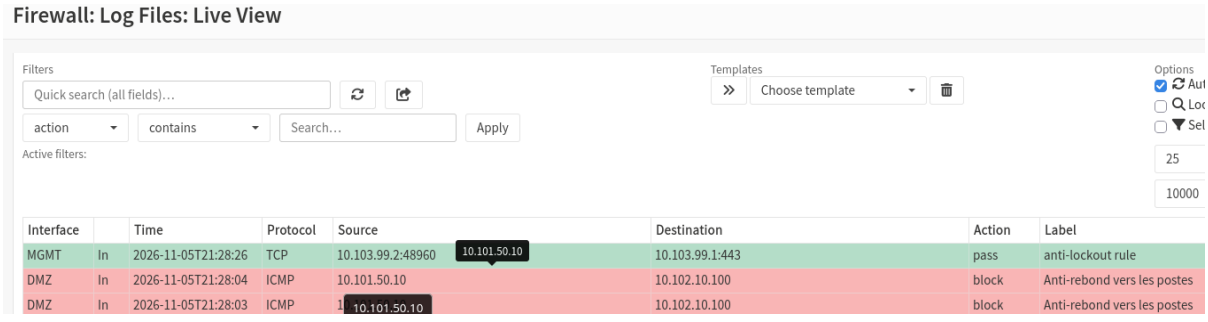
Objectif : vérifier que la règle D1 empêche un serveur de la DMZ d'atteindre le réseau des postes.

Commande : ping -c 2 -W 2 10.102.10.100 depuis srv-website (10.102.10.100 est l'adresse du poste).

```
/ # ping -c 2 -W 2 10.102.10.100
PING 10.102.10.100 (10.102.10.100): 56 data bytes

--- 10.102.10.100 ping statistics ---
2 packets transmitted, 0 packets received, 100% packet loss
/ #
```

- ***ping de srv-website vers un poste : 2 paquets envoyés, 0 reçu (100 % de perte)***



- ***journal du pare-feu (Live View) : blocage de l'ICMP entre 10.101.50.10 et 10.102.10.100 par la règle « Anti-rebond vers les postes »***

Analyse : le ping reste sans réponse, et le journal montre une ligne rouge : interface DMZ, trafic entrant, protocole ICMP, de 10.101.50.10 (srv-website) vers 10.102.10.100 (le poste), action « block », avec la description de la règle D1. La coupure vient donc bien du pare-feu. On voit aussi, sur la ligne verte du dessus, que mon PC d'administration (10.103.99.2) accède bien à l'interface web 10.103.99.1 sur le port 443 : c'est la règle automatique « anti-lockout ».

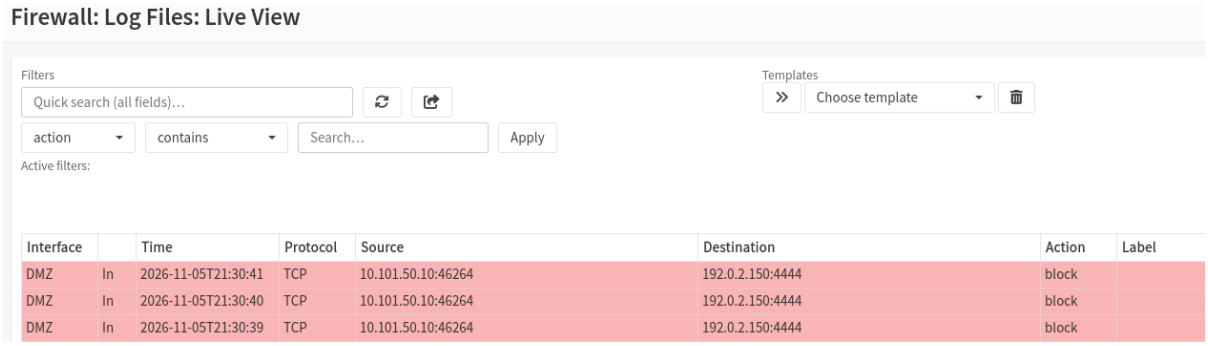
6.4 Test T10 : un shell inverse est bloqué

Objectif : vérifier qu'un serveur de la DMZ ne peut pas ouvrir de connexion sortante sur un port non autorisé. Le port 4444 est celui souvent utilisé par défaut pour un shell inverse.

Commande : curl -m 3 http://192.0.2.150:4444 depuis srv-website.

```
/ # curl -m 3 http://192.0.2.150:4444
curl: (28) Connection timed out after 3002 milliseconds
/ #
```

tentative de connexion sortante de srv-website vers le port 4444 : délai d'attente dépassé



- ***journal du pare-feu : blocage de 10.101.50.10 vers 192.0.2.150, port 4444, en entrée de l'interface DMZ***

Analyse : la commande reste sans réponse jusqu'au délai de 3 secondes, ce qui correspond à un paquet jeté. Le journal le confirme : trois lignes rouges à une seconde d'intervalle (21:30:39, 21:30:40, 21:30:41), qui sont les tentatives successives de connexion du client, toutes bloquées. Comme la destination n'a pas besoin d'être joignable pour que ce résultat soit valable (le paquet est arrêté avant de partir de la DMZ), la ligne de journal est la preuve décisive.

Point d'amélioration : la colonne « Label » est vide sur ces lignes, car la règle finale de la DMZ n'avait pas de description au moment du test. Le blocage est bien attribué à l'interface DMZ, mais on ne voit pas quelle règle l'a décidé. J'en retiens qu'une règle de blocage doit toujours avoir une description claire, sinon le journal perd une partie de son intérêt.

6.5 Tests T05 et T06 : l'administration est inaccessible depuis les postes

Objectif : vérifier qu'un poste de travail ne peut pas atteindre l'interface web du pare-feu.

Commandes : curl -k -m 3 https://10.103.99.1 (côté MGMT) et curl -k -m 3 https://10.102.10.1 (adresse du pare-feu côté postes), depuis workstation-1.

```
/ # curl -k -m 3 https://10.102.10.1
curl: (28) Connection timed out after 3002 milliseconds
/ #
```

- ***T06 : depuis un poste, l'interface web du pare-feu côté postes ne répond pas (délai dépassé)***

Interface		Time	Protocol	Source	Destination	Action	Label
USERS	In	2026-11-05T22:11:10	TCP	10.102.10.100:44630	10.103.99.1:443	block	Postes n'administrent pas le FW
USERS	In	2026-11-05T22:11:09	TCP	10.102.10.100:44630	10.103.99.1:443	block	Postes n'administrent pas le FW
USERS	In	2026-11-05T22:11:08	TCP	10.102.10.100:44630	10.103.99.1:443	block	Postes n'administrent pas le FW

- ***T05 : journal du pare-feu, blocage des connexions du poste 10.102.10.100 vers 10.103.99.1 port 443 (règle « Postes n'administrent pas le FW »)***

Analyse : dans les deux cas, la connexion se termine par un timeout et non par un refus : le pare-feu a jeté les paquets. Le journal de T05 montre trois tentatives successives (22:11:08, 22:11:09, 22:11:10) bloquées par la règle U1. L'interface d'administration est donc bien réservée au réseau MGMT.

6.6 Test T01 : le trafic légitime passe

Un blocage n'a de valeur que si le trafic autorisé fonctionne. Depuis un poste, la commande ci-dessous interroge le serveur web de la DMZ :

```
/ # curl http://10.101.50.10
{"hostname": "srv-website", "client_ip": "10.102.10.100"}
```

- ***T01 : un poste obtient la réponse de srv-website en HTTP***

Analyse : le serveur répond avec son nom (srv-website) et l'adresse du client (10.102.10.100). La règle U3 (poste vers DMZ en TCP 80) fonctionne. Les tests montrent donc que la politique est précise : elle autorise l'accès web aux serveurs, mais bloque le ping. l'administration et les connexions de la DMZ vers les postes.

6.7 Tests non réalisés

Les tests qui dépendent de la liaison avec l'Internet simulé (accès au site Rhodes, accès depuis Internet vers srv-website avec le DNAT, ping depuis Internet) n'ont pas pu être réalisés : la liaison WAN ne fonctionnait pas et je n'en ai pas identifié la cause. Je ne présente donc aucun résultat pour ces tests.

7. Scénario d'incident

Hypothèse : le serveur srv-website est compromis par un attaquant. Les tests T07 et T10 reproduisent ses deux premières actions.

Étape	Description
Action de l'attaquant	Tente d'atteindre les postes (T07), puis d'ouvrir une connexion sortante sur le port 4444 (T10).
Détection	Lignes rouges dans les journaux du pare-feu : une pour l'ICMP vers un poste (description « Anti-rebond vers les postes »), d'autres pour le port 4444 depuis la DMZ.
Effet	Aucune connexion établie : le rebond vers les postes et la sortie sur un port arbitraire sont bloqués.
Cause du blocage	DMZ vers postes refusé, et sortie de la DMZ limitée au web (ports 80 et 443).
Amélioration possible	Alerte automatique en cas de blocages répétés depuis un même serveur (voir partie 9).

Ce scénario montre l'intérêt de la politique : même si le serveur est compromis, l'attaquant reste enfermé dans la DMZ, et ses tentatives laissent des traces qu'un analyste peut lire.

8. Limites

Limites de ce travail

La liaison avec l'Internet simulé ne fonctionnait pas : le NAT (DNAT et SNAT), l'accès à l'extérieur et les tests depuis Internet n'ont pas été validés.

Les tests ont été faits manuellement, un par un, et les journaux sont lus à la main.

Une partie des règles n'a pas de description (règle finale de la DMZ, certaines règles des postes), ce qui rend les journaux moins lisibles.

9. Bilan : compétences développées

Ce projet est un travail d'apprentissage réalisé en laboratoire. Il m'a permis de pratiquer, de bout en bout, la mise en place et la vérification d'une politique de filtrage.

Compétence	Ce que j'ai fait	Où le voir
Configuration d'un pare-feu	Interfaces, alias, règles par interface, ordre des règles, NAT (OPNsense)	Parties 4 et 5
Segmentation réseau et DMZ	Quatre zones séparées, politique de flux entre chaque zone	Parties 3 et 4
Moindre privilège et filtrage sortant	Sorties limitées au web, refus par défaut, accès aux serveurs en TCP 80 seulement	Parties 4, 6.4 et 6.6
Analyse de journaux (Blue Team)	Lecture du Live View, rattachement d'un blocage à son interface et à sa règle	Parties 6.3 à 6.5
Méthode de test et de preuve	Attendu / obtenu, test négatif et positif, distinction timeout / refus	Partie 6
Raisonnement en menaces	Scénario de serveur compromis relié aux tactiques d'attaque (mouvement latéral, commande et contrôle)	Parties 2 et 7
Virtualisation et diagnostic Linux	GNS3, QEMU/KVM, interface tap, résolution de pannes	Partie 8
Rédaction technique	Documentation, schémas, captures commentées, limites assumées	Ce rapport